

Configuring alerts for suspicious behaviours

Lesson 3.5, the end of Topic 3 (Monitoring Tools), and the summary of Lab 2

Saturday, October 3, 2026, online class
Asen Grozdanov, Cyber.SoHo



© 2026 Cyber.SoHo. Educational material for an isolated, authorized lab only.

[Cyber.SoHo Legal Notice, Terms of Use and Acceptable Use Policy](#)



AL-02 Critical, 07:54

Success after repeated failures



AL-07 High, 02:00

486 megabytes sent to the Internet



AL-03 Medium, 06:42

Logon outside office hours



AL-09 High, 08:00

Firewall silent for 20 minutes

Before we start: the rules of this material

Legal header of this material

Educational material — Cyber.SoHo / Asen Grozdanov. © 2026 Cyber.SoHo. All rights reserved. For use in an isolated, authorized lab environment only, against the targets this exercise designates. Applying these tools or techniques to any other system, network or data without the owner's express written authorization may be a criminal offence (Criminal Code, ss. 342.1, 342.2, 430(1.1) and 184) and is strictly prohibited. You alone are responsible for your actions and your equipment. Full terms: Cyber.SoHo Legal Notice, Terms of Use and Acceptable Use Policy, v2.0, section 7.

1

Lab only

Work only in your isolated, authorized lab, on the designated targets ([§6.1](#), [§6.4](#)).

2

Personal information

Logs, baselines and alerts contain names, times and addresses: keep them in the lab ([§7.2](#)).

3

No automated blocking

Alerts inform people; any action on a real system needs written approval ([§7.4](#)).

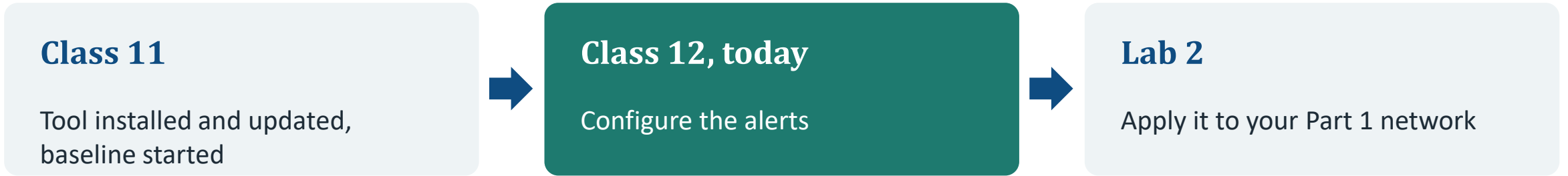
4

Full terms

Read the full text: [Cyber.SoHo Legal Notice, version 2.0](#).



Where we are and what you will learn



By the end of the hour, you can:

- 1** Identify predefined suspicious behaviours and write each one as a complete alert rule
Competency EZ01, criterion 3.2
- 2** Calculate an alert threshold from baseline data and justify it with numbers
- 3** Give each alert a severity, a channel, a recipient and an escalation path, within the time available
- 4** Test alerts with safe test events, measure the results and record them
Competency EZ01, criterion 3.5

Our running example: Ébénisterie Val-des-Pins

The company (fictional)

- Ébénisterie Val-des-Pins Inc., Laval, 22 employees
- Monitoring server MON-01 runs the Wazuh pilot chosen in Class 8
- One monitoring technician: 60 minutes of monitoring per day (Lesson 2.5)
- Priority hosts: FW-01 (firewall), SW-01 (switch), SRV-FILE-01 (file server), PC-ACCT-01 (accounting computer)
- CNC-PC-01 drives the CNC (Computer Numerical Control) machine

Need N-01

- Logs of FW-01, SRV-FILE-01, PC-ACCT-01 and SW-01
- Kept 90 days, within 200 gigabytes
- E-mail alert within 5 minutes

Known gap

- CNC-PC-01 cannot receive an agent (vendor contract)
- Only the connections recorded by FW-01 can be watched

Plan of the hour

Minutes	Part	What you will do
0–3	Opening	Where we are, learning outcomes, running example
3–16	3.5.1 From events to alerts	Parts of an alert rule, five rule types, alert catalogue, replay program
16–29	3.5.2 Thresholds from the baseline	Mean, standard deviation, percentile, profiles, multiplier k and floor
29–41	3.5.3 Severity, notification and escalation	Severity scales, channels, recipients, escalation, alert fatigue
41–53	3.5.4 Testing, tuning and documenting	Four outcomes, precision and recall, safe tests, alert register
53–60	Lab 2 summary and review	What Lab 2 asks, rules, terms of the lesson, next class

Each part ends with a real-life example, a program, a figure, a video and a quick check.

One Monday at Val-des-Pins, as seen by today's rules

Time	Alert	Severity	Host	What happened
02:00:40	AL-07	High	PC-ACCT-01	486.0 megabytes sent to the Internet in one hour
03:00:40	AL-07	High	PC-ACCT-01	512.4 megabytes sent in the next hour
06:42:15	AL-03	Medium	PC-ACCT-01	acct.clerk logged on outside office hours
07:53:12	AL-01	High	SRV-FILE-01	5 failed logons for admin.it in 71 s
07:54:30	AL-02	Critical	SRV-FILE-01	success for admin.it after repeated failures
07:56:05	AL-04	High	SRV-FILE-01	svc.backup2 added to Administrators
07:58:40	AL-05	Critical	SRV-FILE-01	Security log cleared by admin.it
08:00:00	AL-09	High	FW-01	no log received for 20 min

By the end of the hour you can explain every line: which rule produced it, why it has this severity, who is told and how the rule was tested.

From events to alerts

1 Event

One recorded occurrence, stored as a **log entry** made of **fields**: time, host, account, event number, result.

Example: a logon, a failed logon, a file change.



2 Suspicious behaviour

An activity or pattern that does not prove an attack but appears often during attacks.

Predefined: decided in advance and written down (criterion 3.2).

Example: five failed logons in one minute.



3 Alert

A notification produced when the data satisfy a written condition: the **alert rule**, or detection rule.

Example: AL-01 fires at the fifth failure.

A small network records thousands of events every hour, and almost all of them describe normal work. An alert is a request for human attention, not a verdict: a person decides what happened.

The seven parts of an alert rule (1/2)

Val-des-Pins example

- | | | | |
|----------|------------------------------|--|---|
| 1 | Data source | The log or device that provides the evidence. | <i>FW-01, SRV-FILE-01, PC-ACCT-01 and SW-01 (need N-01)</i> |
| 2 | Match condition | The field values that an event must contain. | <i>Windows event 4625: an account failed to log on</i> |
| 3 | Count and time window | How many matching events, within how much time. A sliding window moves with time. | <i>5 failures within 120 seconds</i> |
| 4 | Grouping key | The field that must have the same value in all the counted events. | <i>The account name: five different employees are not one burst</i> |



The seven parts of an alert rule (2/2)

Val-des-Pins example

5

Severity

How serious the possible consequence is (Lesson 3.5.3).

High for AL-01

6

Notification

Who is told, through which channel and how fast (Lesson 3.5.3).

E-mail to the monitoring technician within 5 minutes

7

Response note

The first checks, written in advance so that nobody improvises.

Which address? Ask the account owner. Look for AL-02.

Write all seven parts for every rule, even when the tool does not need all of them: another person can then review, test and approve the rule.



Five types of alert rules (1/2)

1 Single event

Checks: One event with given field values, rare and serious.

Remembers: Nothing.

Example: AL-05: Windows event 1102, the audit log was cleared.

2 Threshold

also called frequency rule

Checks: The number of matching events inside a time window.

Remembers: The recent matching events.

Example: AL-01: 5 failed logons within 120 seconds.

3 Baseline deviation

also called anomaly rule

Checks: A measured value against the normal range of the baseline.

Remembers: The statistics of the baseline.

Example: AL-07: outbound megabytes per hour of PC-ACCT-01.



Five types of alert rules (2/2)

4 Sequence

also called correlation rule

Checks: Different events in a given order within a time window.

Remembers: That the first event happened.

Example: AL-02: a success within 10 minutes after AL-01, same account.

5 Absence

also called heartbeat rule

Checks: An expected event that does not arrive.

Remembers: The time of the last event of each source.

Example: AL-09: FW-01 silent for 15 minutes.

How to tell them apart

Ask what the tool must remember between two events: nothing, recent events, statistics, a first event, or the time of the last event.

Correlation means linking events, from one or several sources, that belong to the same activity.

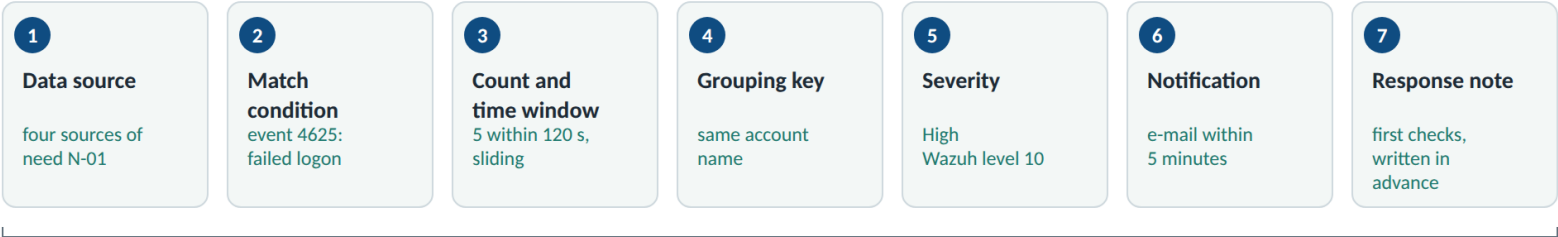
A missing log is a fault or an attempt to hide activity: either way, visibility is lost.



The parts and the types in one picture

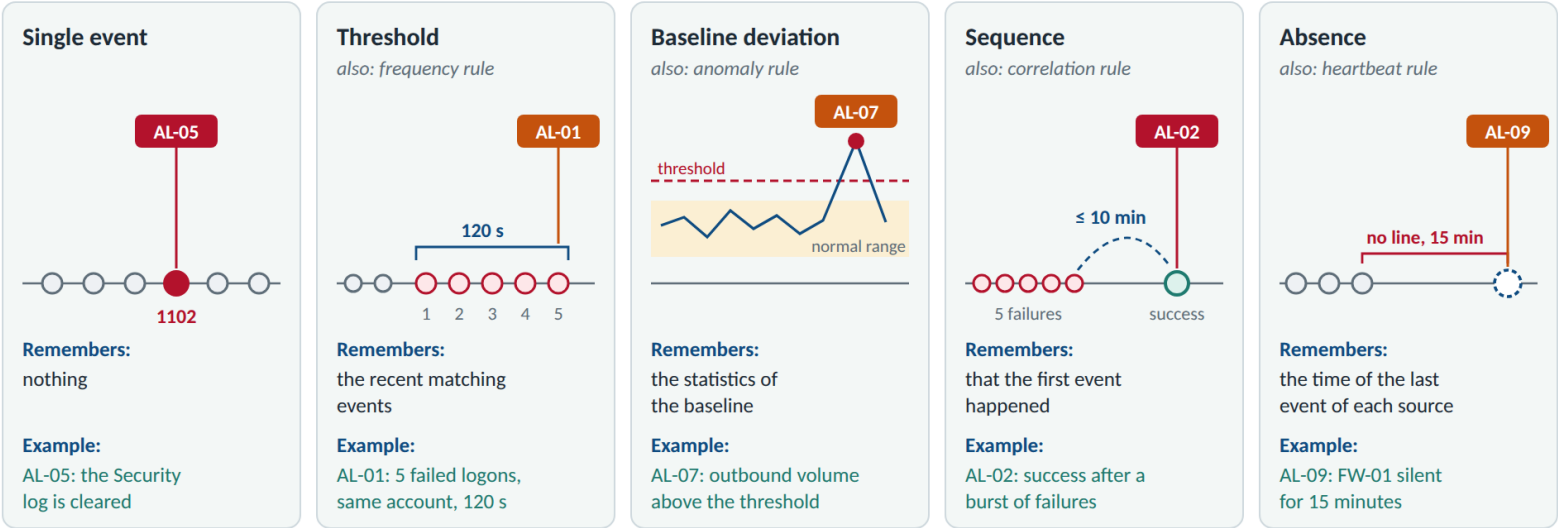
Figure 3.5.1 The parts of an alert rule and the five rule types

Ébénisterie Val-des-Pins, alert catalogue of Lesson 3.5.1



One rule card per alert: every part is written, tested and reviewed before the rule is trusted

Five rule types: what the tool must remember between two events



What to look at

- Top: the seven parts, written on one rule card per alert
- Bottom: the five rule types
- Each type with the Val-des-Pins alert that uses it
- Read the line Remembers in each panel
- Figure 3.5.1, in the companion files



Where do suspicious behaviours come from?

1 Your monitoring plan

From Lab 1: the priority assets, their monitoring needs and the gaps you documented, such as CNC-PC-01 without an agent.

2 Attacker techniques

[MITRE ATT&CK](#) (Adversarial Tactics, Techniques, and Common Knowledge) gives each technique an identifier:

[T1110.001 Password Guessing](#)

[T1070.001 Clear Windows Event Logs](#)

3 System documentation

Microsoft describes each Windows event: [4625](#) failed logon, [4624](#) successful logon, [4732](#) member added to a group, [1102](#) audit log cleared.

[Wazuh rules syntax](#)

Public frameworks describe the same need: the [NIST CSF 2.0](#) (National Institute of Standards and Technology Cybersecurity Framework), outcome DE.AE-06, and the [Canadian Centre for Cyber Security](#) guidance on logging and monitoring.

From the rule card to Wazuh

```
RULE AL-01    Repeated failed logons    v1.0
Source        SRV-FILE-01, PC-ACCT-01
Match         Windows event 4625
Count         5 or more within 120 s
Group by      target account name
Severity      High (Wazuh level 10)
Notify        e-mail within 5 minutes
Silence       600 s after firing
Response      1. Which address?
               2. Ask the account owner.
               3. Look for AL-02.
Reference     T1110.001 Password Guessing
```

Alert records are personal information: keep them in the lab ([Legal Notice §7.2](#)).

Where each part goes in Wazuh 4.x

- Severity: **level** (0 to 16)
- Count and window: **frequency** and **timeframe**
- Grouping key: **same_field** or **same_srcip**
- Earlier rule of a sequence: **if_matched_sid**
- Time conditions: **time** and **weekday**
- Silence after firing: **ignore**
- File: /var/ossec/etc/rules/local_rules.xml, identifiers 100000 to 120000 ([custom rules](#))
- Wazuh rules compare fields; they do not calculate averages
- Stable version: 4.14.8 (September 2026)

Example 3.5.1: the alert catalogue (1/2)

Task: turn the predefined suspicious behaviours of Val-des-Pins into nine written alert rules.

Alert	Suspicious behaviour	Rule type	Condition	Severity
AL-01	Repeated failed logons (password guessing)	Threshold	5 or more failures within 120 s, same account	High
AL-02	Successful logon right after repeated failures	Sequence	Success within 10 min after AL-01, same account	Critical
AL-03	Logon outside office hours on the accounting computer	Single event and time	Logon type 2 or 10 outside Monday to Friday, 07:00 to 18:00	Medium
AL-04	Account added to the local Administrators group	Single event	Event 4732 without an approved change	High
AL-05	Security audit log cleared	Single event	Event 1102, any occurrence	Critical

Example 3.5.1: the alert catalogue (2/2)

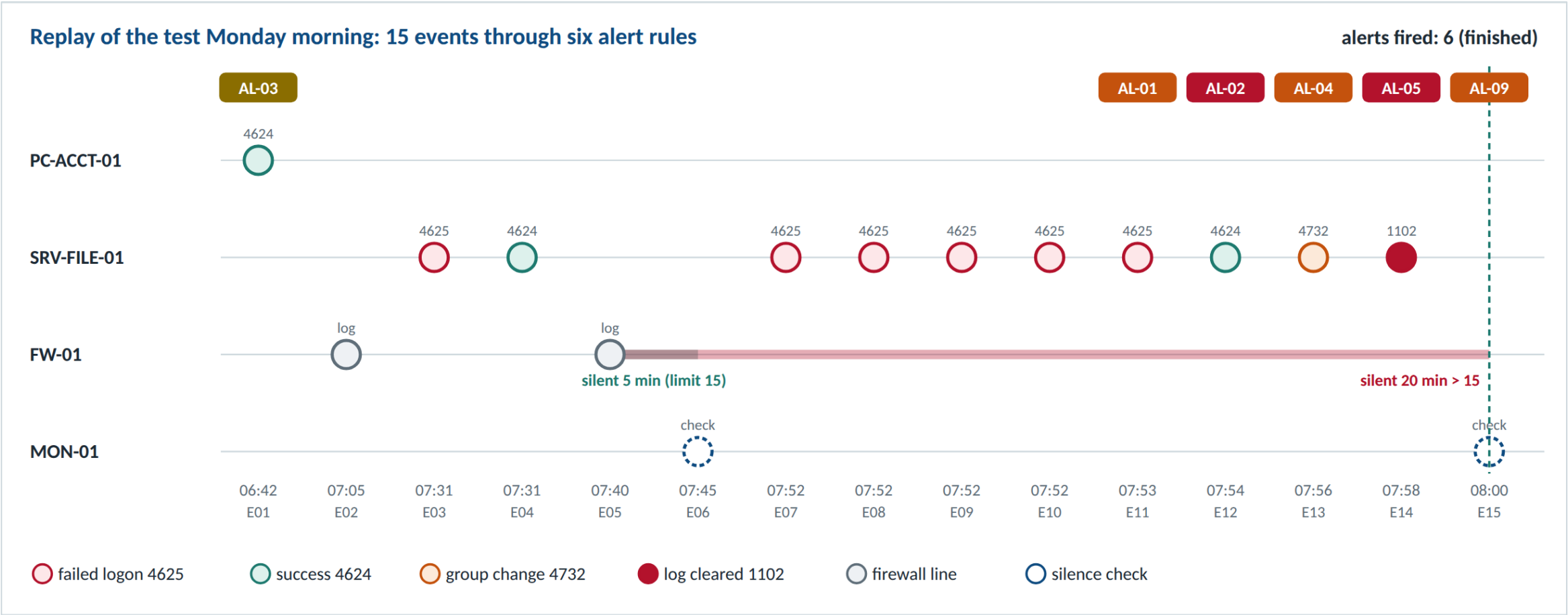
Alert	Suspicious behaviour	Rule type	Condition	Severity
AL-06	Mass file changes in the shared folders	Threshold from the baseline	Above the baseline threshold for 5 minutes (file integrity monitoring)	Critical
AL-07	Unusual outbound volume of PC-ACCT-01	Baseline deviation	Above the larger of mean + 3 × standard deviation and 25 megabytes, per profile	High
AL-08	CNC-PC-01 contacts a destination not on the vendor list	Single event and allowlist	Any such connection recorded by FW-01	High
AL-09	Log source silent	Absence	No line from FW-01 for 15 minutes	High

Deliverables and the labs they feed

The catalogue is the starting list of your Lab 2 alerts, adapted to your own lab network. The replay of one Monday morning (next slide) is the scenario of Lab 3.



Code example 3.5.1: replaying one Monday morning



15 synthetic events, six rules, six alerts: AL-03, AL-01, AL-02, AL-04, AL-05 and AL-09. Program: class12_alert_rules.py (companion files); run it with `python3 class12_alert_rules.py`.

Watch and check: Lesson 3.5.1



Indicators of Compromise

Professor Messer, 10:59 minutes

Presents account lockouts, impossible travel, resource consumption, out-of-cycle logging and missing logs: the behaviours from which predefined suspicious behaviours are chosen.

[Watch on YouTube](#) [Official course page](#)

Check yourself

- 1 Windows event 1102 appears once on a server. Which type of rule fires?
- 2 Five failures for admin.it arrive between 07:52:01 and 07:53:12. When does AL-01 fire?
- 3 Which part of a rule stops one failure from each of five employees from counting as a burst?

Answers: self-check of the lecture page.

Why the threshold number matters

Threshold too low

Normal activity raises alerts: **false positives**. They waste review time and tire the team.

Threshold too high

Real problems pass without an alert: **false negatives**. The team believes that it is protected when it is not.

Two ways to choose the number

Static threshold

A fixed number from knowledge or policy. Suits values that are normally close to zero.

Example: 5 failed logons within 120 seconds.

Baseline-derived (dynamic) threshold

Calculated from measurements of normal activity. Suits values that change with the hour and the day.

Example: outbound megabytes per hour.

Three statistics of a baseline

Mean

36.2

megabytes per hour, office hours

The sum of the n values divided by n.

Standard deviation

10.4

how far the values usually are from the mean

Sample formula: square root of the sum of squared differences, divided by $n - 1$.

99th percentile

53.1

99 % of the hours are at or below it

Nearest rank: sort the values, take rank $[0.99 \times n]$ (rank 109 of 110).

For bell-shaped (normal) data, about 68 % of the values lie within 1 standard deviation of the mean, 95 % within 2 and 99.7 % within 3. Monitoring data are often not bell-shaped: always compare with the real counts of your baseline.

Profiles: one threshold per type of hour

Office hours

Monday to Friday, 07:00 to 18:00

110

hours

36.2

mean

10.4

standard deviation

megabytes per hour, PC-ACCT-01

Off hours

all other hours

226

hours

3.0

mean

1.0

standard deviation

megabytes per hour, PC-ACCT-01

Normal activity at 10:00 on a Tuesday is not normal activity at 02:00 on a Sunday. Each profile gets its own mean, standard deviation and threshold.



The multiplier k and the minimum floor

threshold of a profile = the larger of (mean + $k \times$ standard deviation) and the floor

k Multiplier k

- Larger k: fewer false positives, more risk of false negatives
- Count the baseline hours above each candidate
- Hours above $\div$ weeks of baseline = expected false alarms per week
- Val-des-Pins: k = 2 gives 57.0 and 0.5 false alarm per week; k = 3 gives 67.5 and none

25 Minimum floor

- An absolute value below which no alert is raised
- A documented business decision, not a statistical result
- Val-des-Pins: 25 megabytes per hour
- At night, mean + $3 \times$ standard deviation is only 5.9, so the floor applies

Keep the baseline clean and current

- 1 Remove the periods with known incidents or planned exceptional work (a migration, a year-end closing).
- 2 Check that every day of the week is covered.
- 3 Record the baseline period and the date of the calculation.
- 4 Recalculate the thresholds when the baseline is updated (Topic 6.1).
- 5 Review them at least once a month: [CIS Controls](#) (Center for Internet Security), safeguard 13.11.

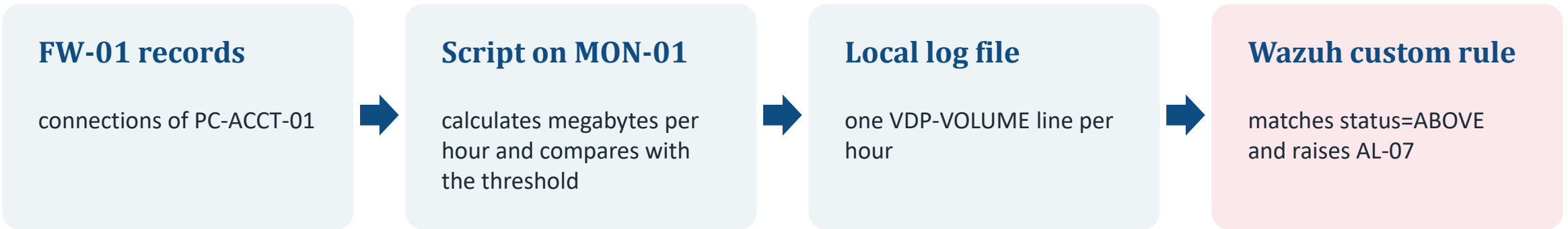
Why it matters

A threshold is only as reliable as the baseline behind it.

Abnormal days in the baseline raise the mean and the standard deviation, so real problems can hide below the threshold.



How Wazuh uses a calculated threshold



```
VDP-VOLUME host=PC-ACCT-01 hour=02 mb=486.0 profile=off-hours threshold=25.0 status=ABOVE
```

- For counts, the threshold goes straight into the rule: frequency="5" and timeframe="120" for AL-01.
- Wazuh rules compare fields; they do not calculate means, so the calculation stays in the script.
- The alert, its severity and its notification stay in Wazuh ([monitoring log files](#)).

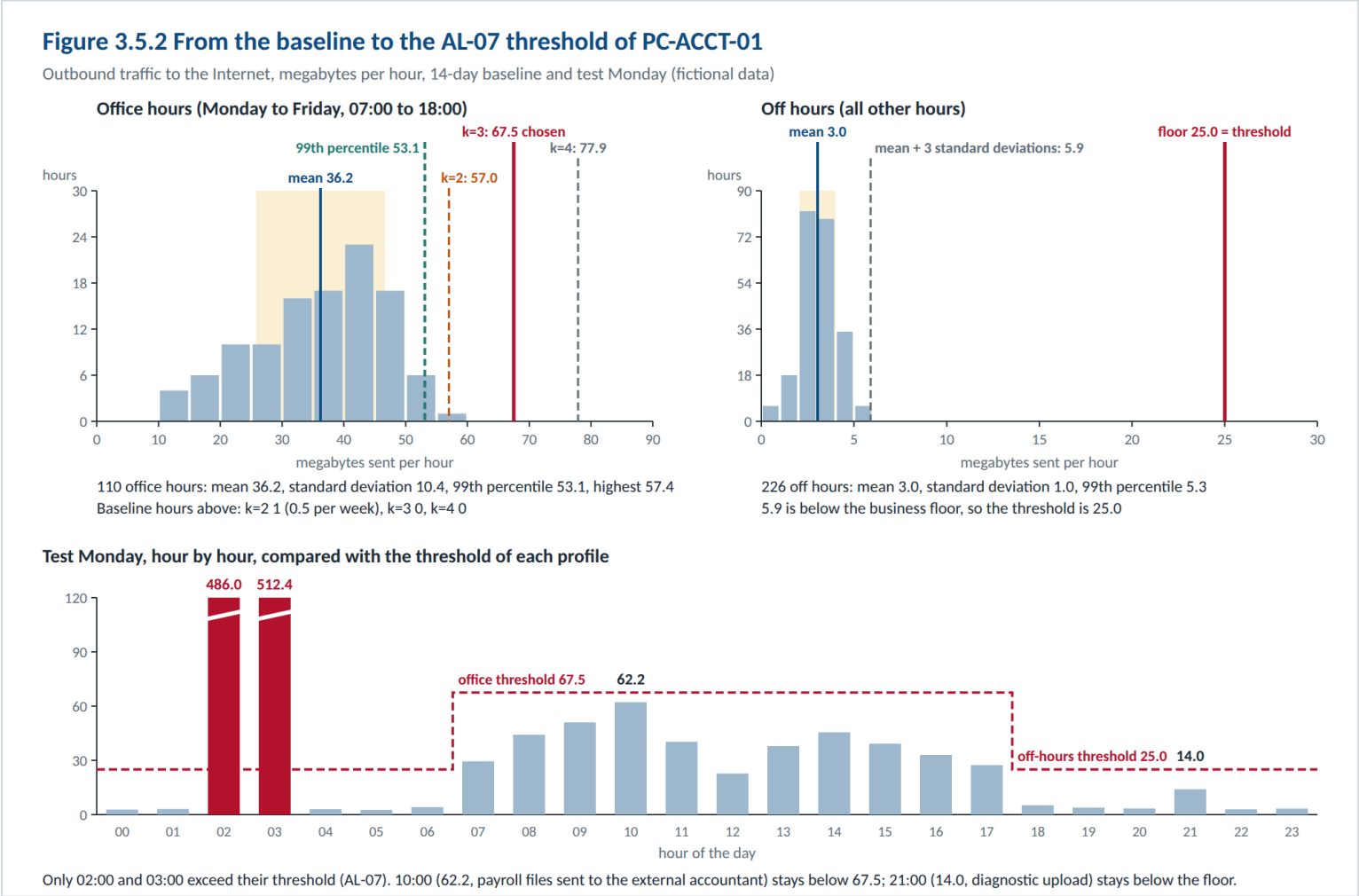
Example 3.5.2: the AL-07 threshold of PC-ACCT-01

Task: calculate the threshold from 14 days of hourly baseline data, compare k = 2, 3 and 4, and check the test Monday.

Profile	k	Mean	Standard deviation	Mean + k × standard deviation	Threshold with the floor	Baseline hours above	False alarms per week
Office hours	2	36.2	10.4	57.0	57.0	1	0.5
Office hours	3	36.2	10.4	67.5	67.5	0	0
Office hours	4	36.2	10.4	77.9	77.9	0	0
Off hours	2	3.0	1.0	5.0	25.0	0	0
Off hours	3	3.0	1.0	5.9	25.0	0	0
Off hours	4	3.0	1.0	6.9	25.0	0	0

Test Monday: 486.0 and 512.4 megabytes at 02:00 and 03:00 exceed 25.0: two AL-07 alerts. 62.2 at 10:00 (payroll files) stays below 67.5; 14.0 at 21:00 stays below the floor.

The baseline and the thresholds in one picture



What to look at

- Top left: 110 office hours, the mean, the band of one standard deviation and the 99th percentile
- Candidate lines k = 2, 3 and 4; k = 3 chosen: 67.5
- Top right: off hours, where the floor of 25.0 applies
- Bottom: the test Monday; only 02:00 and 03:00 cross their threshold



Code example 3.5.2: calculating the threshold



What the program does

- Reads 360 hourly values: 336 baseline hours and 24 test hours
- Splits them into the two profiles
- Computes mean, standard deviation and 99th percentile
- Compares k = 2, 3 and 4 and applies the floor
- Test Monday: ABOVE at 02:00 and 03:00
- File: class12_baseline_thresholds.py with its data file



Watch and check: Lesson 3.5.2



Logs and Monitoring

Professor Messer, 13:06 minutes

Explains the network performance baseline, the picture of a normal day for each device, and how a management console alerts when values leave that normal range.

[Watch on YouTube](#) [Official course page](#)

Check yourself

- 1 A profile has a mean of 40 and a standard deviation of 8. What is mean + 3 × standard deviation?
- 2 At night: mean 3.0, standard deviation 1.0, floor 25. Does 14.0 megabytes raise an alert?
- 3 What happens to false positives and false negatives when k goes from 2 to 4?

Answers: self-check of the lecture page.



Severity and priority

Critical

Evidence of an attack in progress, or of an attempt to hide activity, on a priority asset

AL-02, AL-05, AL-06

High

Behaviour that often comes before an attack, or loss of visibility on a priority asset

AL-01, AL-04, AL-07, AL-08, AL-09

Medium

Unusual behaviour with frequent legitimate causes

AL-03

Low

Information for context and trends, no action by itself

An agent that reconnects

Priority is the order of handling: severity + importance of the asset (Lesson 2.5) + time of day.



Read severity numbers in the right direction

Wazuh levels: 0 to 16

A higher number is more serious. Level 12 is a "high importance event"; alerts are stored from level 3.

Course level	Wazuh levels
Critical	13 to 16
High	10 to 12
Medium	7 to 9
Low	3 to 6

Syslog severities: 0 to 7

[RFC 5424](#) (Request for Comments): a lower number is more serious.

Number	Name
0	Emergency: system is unusable
1	Alert: action must be taken immediately
2	Critical: critical conditions
3	Error: error conditions
4	Warning: warning conditions
5	Notice: normal but significant condition
6	Informational: informational messages
7	Debug: debug-level messages

Notification channels and the Wazuh e-mail settings

Dashboard

A screen that someone must open.

E-mail

Need N-01: within 5 minutes.

Text message or call

Interrupts people: kept for Critical.

Ticket

A help-desk record that is followed up.

Faster channels interrupt people, so they are kept for the most serious levels. In the lab, e-mails go to a local mailbox on MON-01 ([Legal Notice §6.4](#)).

Wazuh e-mail settings

- Global section of ossec.conf: email_notification, smtp_server, email_from, email_to
- Default **email_alert_level** 12: only levels 12 and above are e-mailed
- Default **email_maxperhour** 12: extra alerts are grouped at the end of the hour
- No login to a mail server: Wazuh needs a local mail relay
- AL-01 is level 10: lower email_alert_level to 10, or add **alert_by_email** to the High rules
- [Alert management](#) and [global options](#)

Recipients, acknowledgement and escalation

Recipient

- 1
- Named by role, not by person, so that the rule survives holidays and staff changes.

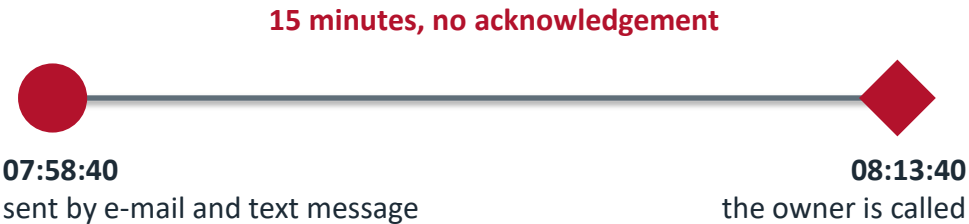
Acknowledgement target

- 2
- The maximum time before someone confirms: I am handling this alert.

Escalation

- 3
- The next role to notify when nobody acknowledges in time.

AL-05 on the test Monday



Accepted risk

No night staff: High alerts at night are delivered at once but read at 07:00. The owner decides this in writing.

Val-des-Pins: the monitoring technician receives every alert; the owner is called when a Critical alert is not acknowledged within 15 minutes.



Alert fatigue and the four controls

Alert fatigue: the decline in attention and response quality when people receive more alerts than they can examine. Signs: unread alerts, growing acknowledgement times, rules that everybody ignores.

Deduplication

1

One notification for repeats of the same rule on the same host within a window, with a count.

Grouping (aggregation)

2

One message for several related alerts: the daily digest at 08:00 for Medium alerts.

Rate limiting (throttling)

3

A maximum number of messages per period, such as email_maxperhour.

Documented suppression

4

No notification for an approved activity (a maintenance window), with a reason and an end date.

Budget: 60 minutes per day and about 8 minutes per High alert, so fewer than 8 High alerts per day. Normal days above the budget: tune the rules.

Alerts inform; people decide the actions

In this course, alerts only notify people. They do not block, disable or change anything.

Before any blocking or containment on a real system:

- 1 The owner's written approval**
- 2 A change window**
- 3 A tested rollback**

Automated measures that reach out to, disable or retaliate against another system are prohibited in every course ([Legal Notice §7.4](#)). Wazuh can respond automatically ([active response](#)), but it is not used here.

Example 3.5.3: the notification matrix

Task: decide who is told, how and how fast, then test the matrix on the 15 alerts of the test Monday.

Severity	Channel	Delivery target	Acknowledgement	Escalation	Review time
Critical	E-mail and text message (in the lab: simulated)	At once, at any hour	15 minutes	Owner called by phone after 15 minutes	15 min
High	E-mail	Within 5 minutes (need N-01); read at 07:00 when it arrives at night (accepted risk)	4 office hours	Owner informed at the end of the office day if still not acknowledged	8 min
Medium	Daily digest e-mail and dashboard	Next digest at 08:00	1 office day	None	4 min
Low	Dashboard only	None	None	None	1 min

All levels: same rule and same host within 10 minutes: one notification with a count of the repeats.

Test Monday: 15 alerts give 12 notifications and 3 grouped repeats; AL-05 is escalated at 08:13:40; review workload 92 minutes (116 without grouping) against a budget of 60.

Notification, escalation and deduplication in one picture

Figure 3.5.3 Notification, escalation and deduplication at Val-des-Pins

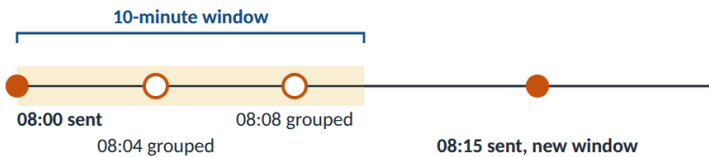
Table 3.5.E applied to the alerts of the test Monday

Severity	Channel	Delivery target	Acknowledgement	Escalation
Critical	E-mail and text message (simulated in the lab)	at once, at any hour	15 minutes	owner called by phone after 15 minutes
High	E-mail	within 5 minutes; at night: read at 07:00	4 office hours	owner informed at the end of the office day
Medium	Daily digest e-mail and dashboard	next digest at 08:00	1 office day	none
Low	Dashboard only	none	none	none

Escalation of AL-05 (not acknowledged)



Deduplication of AL-09 (window of 10 minutes)



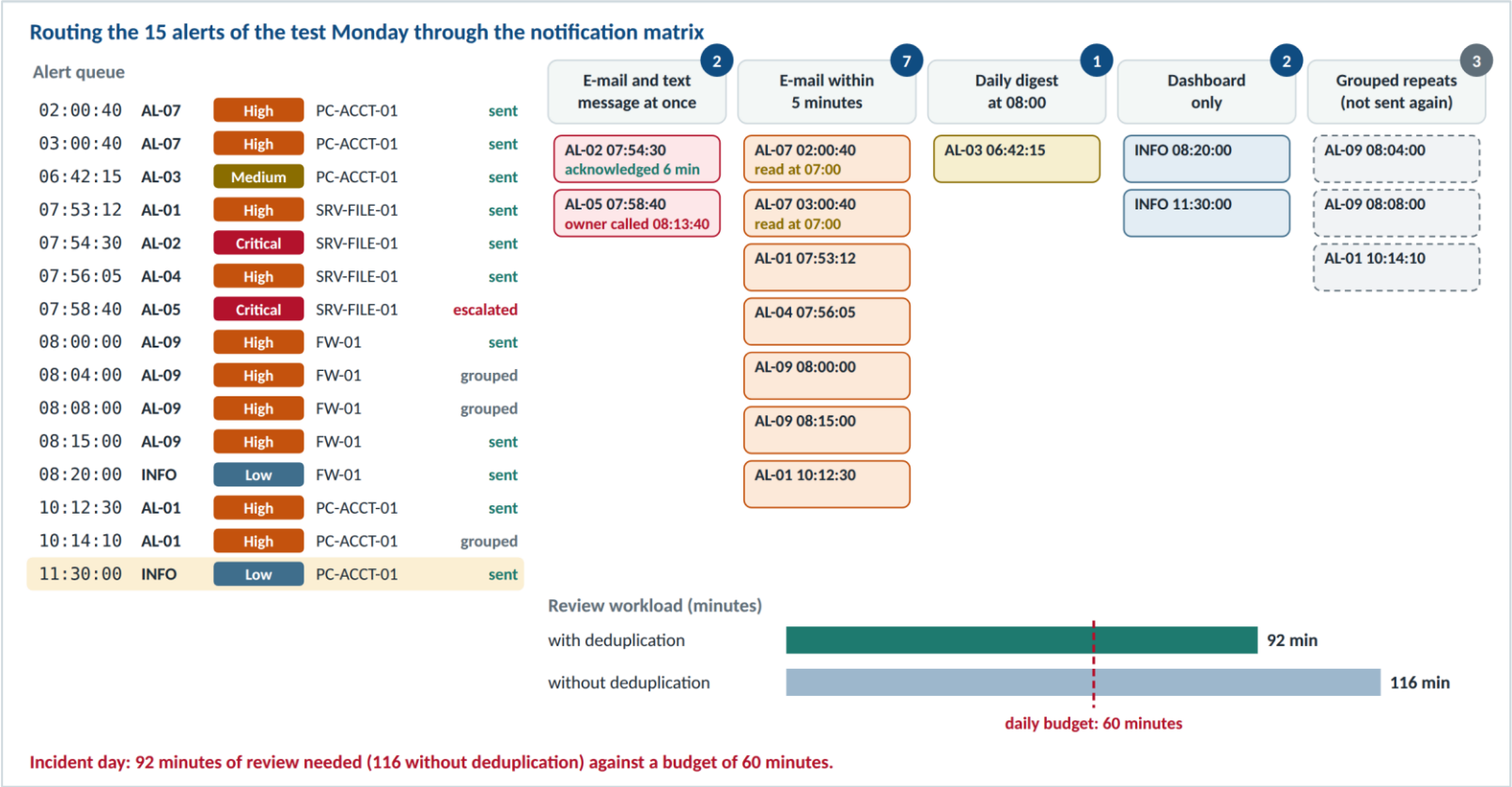
Test Monday: 15 alerts gave 12 notifications (2 e-mail and text message, 7 e-mail, 1 daily digest, 2 dashboard) and 3 grouped repeats.
Review workload: 92 minutes with deduplication, 116 minutes without; daily budget 60 minutes (incident day: the incident procedure takes over).

What to look at

- Top: channel, delivery, acknowledgement and escalation for each severity
- Bottom left: AL-05 is not acknowledged; the owner is called at 08:13:40
- Bottom right: AL-09 repeats at 08:04 and 08:08 are grouped; 08:15 opens a new window



Code example 3.5.3: routing one day of alerts



What the program does

- Applies the matrix to the 15 alerts of the test Monday
- Groups repeats of the same rule and host within 10 minutes
- Escalates AL-05: owner called at 08:13:40
- 12 notifications: 2, 7, 1 and 2 per channel
- Workload: 92 minutes, 116 without grouping, budget 60
- File: class12_alert_routing.py



Watch and check: Lesson 3.5.3



Security Monitoring

Professor Messer, 10:27 minutes

Covers real-time alerts sent by text message or e-mail, separate alerts for a security operations centre, the reaction to an alert and the constant balance between accurate alerts, false positives and false negatives.

[Watch on YouTube](#) [Official course page](#)



Scripting and Automation

Professor Messer, 8:20 minutes

Shows how automation turns a message into a help-desk ticket assigned to the right person and escalates problems, which is the mechanism behind channels, recipients and escalation.

[Watch on YouTube](#) [Official course page](#)

Check yourself

1

AL-01 is a level-10 alert and Wazuh e-mails level 12 and above by default. What do you change?

2

AL-05 is sent at 07:58:40 and nobody acknowledges it; the target is 15 minutes. When is the owner called?

3

Name two controls that reduce alert fatigue without hiding real problems.

Answers: self-check of the lecture page.



Why every alert must be tested

A rule that has never fired may be correct or broken: only a test tells you which.

Positive test

A safe event that **should** trigger the rule.

Expected result: ALERT.

Negative test

A safe event that **should not** trigger the rule. It proves that the rule is not too broad.

Expected result: NO ALERT.

Compare the expected result with the actual result and record the outcome. Only in the lab, on the designated systems, with synthetic data ([§6.4](#), [§6.7](#)).

Four outcomes and two ratios

	Alert raised	No alert raised
Alert expected	True positive The expected alert was raised.	False negative An expected alert was missed: the most dangerous outcome.
No alert expected	False positive An alert without reason: wastes time, feeds fatigue.	True negative Nothing expected, nothing raised.

High precision with low recall: few alerts, but missed problems. High recall with low precision: problems found, but more alerts than people can review.

P Precision

$\text{true positives} \div (\text{true positives} + \text{false positives})$
The share of raised alerts that were justified.

R Recall (detection rate)

$\text{true positives} \div (\text{true positives} + \text{false negatives})$
The share of expected detections that were made.

Producing test events safely

1

The test utility of the tool

[wazuh-logtest](#) or the dashboard page Ruleset Test: paste a sample log line and see which decoder and rule match, without creating a real event.

2

A harmless action on a lab machine

Type a wrong password five times on the lab virtual machine that plays PC-ACCT-01, with a test account.

3

A synthetic log line

Write a synthetic line into a test file that the lab agent reads.

Never on a production system, a shared network or the account of a real person: that creates a real incident for real people.

Saving the rule file is enough for wazuh-logtest; restart the Wazuh manager before the rule raises real alerts ([testing decoders and rules](#)).



Tuning and regression testing

Tuning: the controlled change of a rule

- Narrow a match condition that is too broad (AL-05 version 1.0 matched any line with the word cleared)
- Add a value that was forgotten (logon type 10, remote desktop, for AL-03)
- Adjust a threshold with baseline evidence
- Add a documented exception

Regression testing

After every change, run the whole test plan again: positive and negative tests.

It proves that the correction did not break another detection.

The alert register and version control

One entry per rule in the alert register

- Identifier and version
- Purpose
- Data source
- Condition
- Rule type
- Severity
- Notification
- Response note
- Tests
- Change history
- Owner and approval
- Next review

Changing a rule safely

- Every rule change is a configuration change
- A reason, a test, an approval and a way back: the **rollback** (Class 6)
- Keep each version of local_rules.xml
- Upgrades keep your files in /var/ossec/etc/rules
- Upgrades replace /var/ossec/ruleset/rules: never edit these default files
- Example for AL-03: Table 3.5.G



Example 3.5.4: testing versions 1.0 and 1.1

Version 1.0

5

true positives

1

false positive

1

false negative

4

true negatives

precision 83.3 %, recall 83.3 %

Version 1.1, after tuning

6

true positives

0

false positives

0

false negatives

5

true negatives

precision 100 %, recall 100 %

T06: false positive

AL-05 version 1.0 matched the word cleared in "Browser cache cleared by user". Fix: event 1102 only.

T08: false negative

AL-03 version 1.0 ignored logon type 10 (remote desktop at 22:15). Fix: accept types 2 and 10.

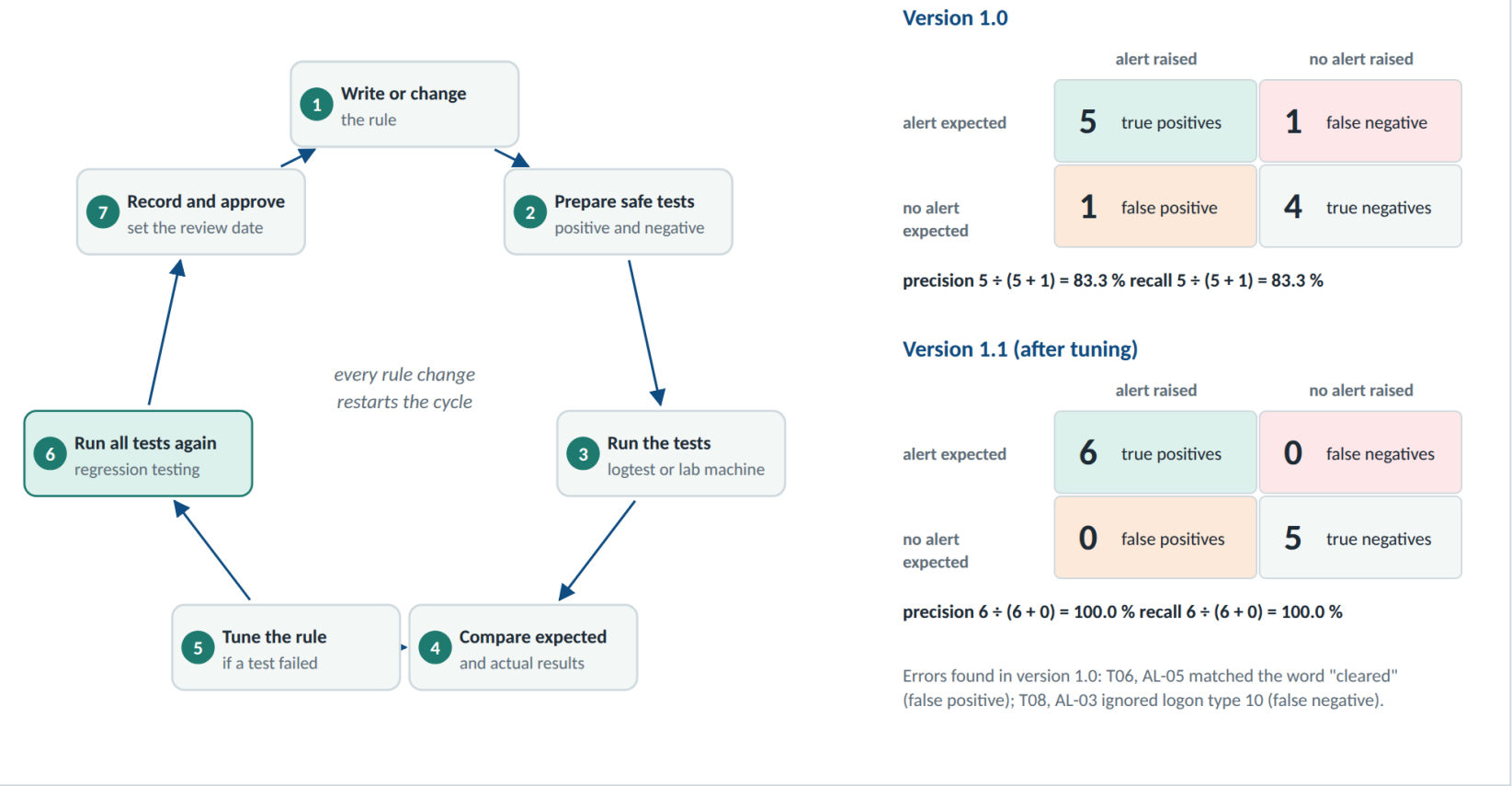
100 % on eleven tests is not 100 % in real use: the test plan grows with every new situation (Topic 6.4).



The test cycle and the results in one picture

Figure 3.5.4 The alert test cycle and the results of versions 1.0 and 1.1

Eleven safe tests on five Val-des-Pins rules (Code example 3.5.4)



What to look at

- Left: the seven steps of the test cycle; every rule change restarts it
- Step 6, regression testing, is highlighted
- Right: the outcomes of versions 1.0 and 1.1



Code example 3.5.4: testing two versions of the rules

Eleven safe tests run against versions 1.0 and 1.1 of the rules

Test	Rule	Expected	1.0 result	1.0 outcome	1.1 result	1.1 outcome
T01	AL-01	ALERT	ALERT	true positive	ALERT	true positive
T02	AL-01	NO_ALERT	NO_ALERT	true negative	NO_ALERT	true negative
T03	AL-04	ALERT	ALERT	true positive	ALERT	true positive
T04	AL-04	NO_ALERT	NO_ALERT	true negative	NO_ALERT	true negative
T05	AL-05	ALERT	ALERT	true positive	ALERT	true positive
T06	AL-05	NO_ALERT	ALERT	false positive	NO_ALERT	true negative
T07	AL-03	ALERT	ALERT	true positive	ALERT	true positive
T08	AL-03	ALERT	NO_ALERT	false negative	ALERT	true positive
T09	AL-03	NO_ALERT	NO_ALERT	true negative	NO_ALERT	true negative
T10	AL-08	ALERT	ALERT	true positive	ALERT	true positive
T11	AL-08	NO_ALERT	NO_ALERT	true negative	NO_ALERT	true negative

Version 1.0

	alert raised	no alert raised
expected	5 true positives	1 false negative
not expected	1 false positive	4 true negatives

precision 83.3 % recall 83.3 %

Version 1.1

	alert raised	no alert raised
expected	6 true positives	0 false negatives
not expected	0 false positives	5 true negatives

precision 100.0 % recall 100.0 %

Faults of version 1.0: AL-05 matched the word "cleared"; AL-03 accepted logon type 2 only.

What the program does

- Eleven safe tests, positive and negative
- Rules written as patterns, versions 1.0 and 1.1
- Classifies each outcome
- Computes precision and recall with awk
- Writes the test record: 22 lines of evidence
- File: class12_alert_tests.sh (bash)

Watch and check: Lesson 3.5.4



Analyzing Vulnerabilities

Professor Messer, 10:29 minutes

The context is vulnerability scanning, but the video gives clear definitions of false positives and false negatives and explains why a false negative is the more dangerous error.

[Watch on YouTube](#) [Official course page](#)



Technical Change Management

Professor Messer, 10:54 minutes

Explains scope, documentation updates and version control of technical changes, the discipline that applies every time you modify an alert rule.

[Watch on YouTube](#) [Official course page](#)

Check yourself

1

A test expected no alert, but the rule raised one. Which outcome is it?

2

5 true positives, 1 false positive, 1 false negative and 4 true negatives: what is the precision?

3

After you tune AL-03, which tests do you run again?

Answers: self-check of the lecture page.



Lab 2 (5 %): Integrative Project, Part 2

1 Install and configure

Wazuh on MON-01; connect the sources of need N-01; apply the updates (Lesson 3.3).

2 Build the baseline

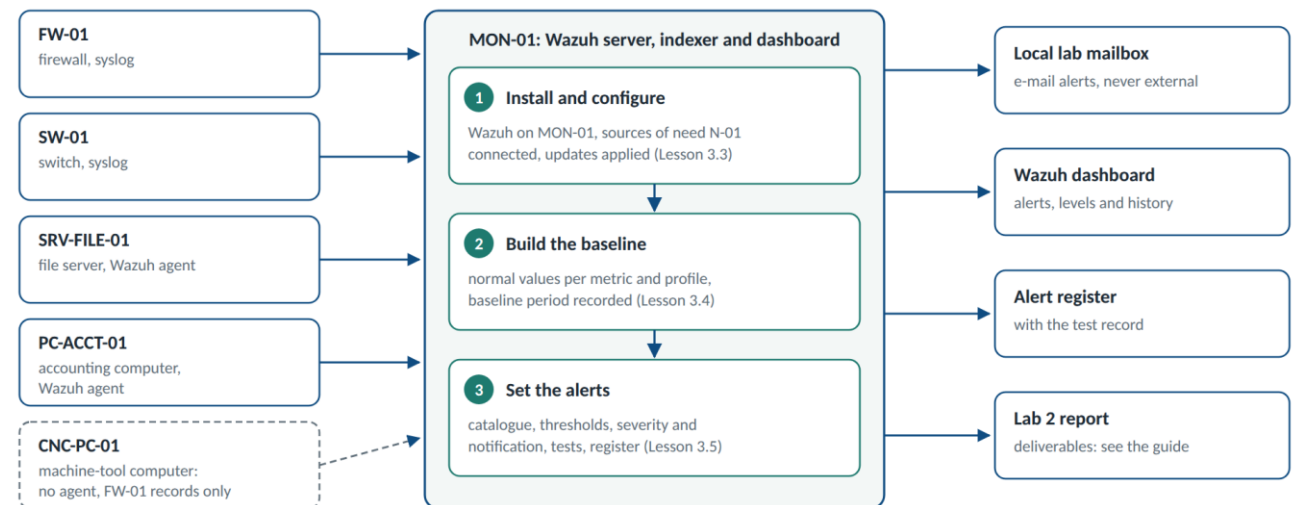
Normal activity for the metrics that you chose (Lesson 3.4).

3 Set the alerts

Today's method: catalogue, thresholds, severity and notification, tests and register.

Figure 3.5.L2 Lab 2 at a glance: install, baseline, alerts

Integrative Project, Part 2, on the Part 1 network rebuilt in the isolated lab



Isolated lab only, synthetic data, no automated blocking: Legal Notice sections 6.4, 7.2 and 7.4

Reuse your Lab 1 map and plan and the Class 8 Tool Selection Record. Your values must come from your own lab.

Guide, due date and grading grid: on Léa ([MyDawson portal](#)).

Rules that apply to Lab 2

- 1 Work only in your Authorized Lab Environment, on the designated targets ([§6.1](#), [§6.4](#)).
- 2 Download Wazuh and every program from its official source and verify its checksum ([§6.6](#), [Annex C](#)).
- 3 Use synthetic data; treat every baseline and alert record as personal information ([§6.7](#), [§7.2](#)).
- 4 Send lab e-mails only to a local lab mailbox; configure no automated blocking ([§7.4](#)).
- 5 Keep lab material confidential and do not record sessions ([§17](#)); submit your own work ([§18](#)).
- 6 The e-signature page for the Annex A acknowledgement will be provided separately ([Annex A](#)).

What to remember

- 1 An alert rule is a written condition with seven parts; its type (single event, threshold, baseline deviation, sequence, absence) tells what the tool must remember.
- 2 Thresholds come from the baseline: one profile per type of hour, the larger of mean + $k \times$ standard deviation and a documented floor, checked against the baseline counts.
- 3 Every alert has a severity, a channel, a recipient, an acknowledgement target and an escalation path, and the total workload must fit the time available.
- 4 No rule is trusted before positive and negative tests; every change is tuned, tested again, recorded and approved.
- 5 All of it happens in the lab, with synthetic data, and alerts inform people; they do not act on real systems.

Next steps

1 Monday, October 5

No class: Provincial Election Day.

2 Thursday, October 8

Class 13, online. Topic 4: 4.1 event logs on Windows and Linux; 4.2 network traffic capture, the basics.

3 Saturday, October 10

Quiz 3 (5 %): all the material to date, including this lesson.

Before Class 13

Download the companion files, run the four programs, open the workbook and read your Lab 2 guide.



Links and resources (1/4)

Course and legal

[Dawson College](http://www.dawsoncollege.qc.ca) www.dawsoncollege.qc.ca

[MyDawson portal \(Omnivox, Léa and MIO, Messaging in Omnivox\)](http://dawsoncollege.omnivox.ca)
dawsoncollege.omnivox.ca

[Cyber.SoHo Legal Notice, Terms of Use and Acceptable Use Policy](https://cyber-soho.github.io) cyber-soho.github.io

Videos of this lesson (Professor Messer)

[Indicators of Compromise](#), 10:59 ([course page](#))

[Logs and Monitoring](#), 13:06 ([course page](#))

[Security Monitoring](#), 10:27 ([course page](#))

[Scripting and Automation](#), 8:20 ([course page](#))

[Analyzing Vulnerabilities](#), 10:29 ([course page](#))

[Technical Change Management](#), 10:54 ([course page](#))

Wazuh documentation (1/2)

[Wazuh](https://wazuh.com) wazuh.com

[Wazuh: rules syntax](https://documentation.wazuh.com) documentation.wazuh.com

[Wazuh: custom rules](https://documentation.wazuh.com) documentation.wazuh.com

[Wazuh: rules classification](https://documentation.wazuh.com) documentation.wazuh.com

[Wazuh: alert management](https://documentation.wazuh.com) documentation.wazuh.com

[Wazuh: global options of ossec.conf](https://documentation.wazuh.com) documentation.wazuh.com

[Wazuh: monitoring log files](https://documentation.wazuh.com) documentation.wazuh.com

Links and resources (2/4)

Wazuh documentation (2/2)

[Wazuh: wazuh-logtest](https://documentation.wazuh.com) documentation.wazuh.com

[Wazuh: testing decoders and rules](https://documentation.wazuh.com) documentation.wazuh.com

[Wazuh: active response](https://documentation.wazuh.com) documentation.wazuh.com

[Wazuh: file integrity monitoring](https://documentation.wazuh.com) documentation.wazuh.com

[Wazuh 4.14.8 release notes](https://documentation.wazuh.com) documentation.wazuh.com

Link and file safety

[VirusTotal: scan an address](https://www.virustotal.com) www.virustotal.com

[VirusTotal: scan a file](https://www.virustotal.com) www.virustotal.com

[Google Safe Browsing: site status](https://transparencyreport.google.com) transparencyreport.google.com

Windows security events (Microsoft)

[Windows event 4625: an account failed to log on](#)

[Windows event 4624: an account was successfully logged on](#)

[Windows event 4732: a member was added to a security-enabled local group](#)

[Windows event 4720: a user account was created](#)

[Windows event 1102: the audit log was cleared](#)

Running the code

[Python downloads](https://www.python.org) www.python.org

[Bash, official page](https://www.gnu.org) www.gnu.org

Links and resources (3/4)

Attacker techniques: MITRE ATT&CK (Adversarial Tactics, Techniques, and Common Knowledge)

[MITRE ATT&CK knowledge base](https://attack.mitre.org) attack.mitre.org

[T1110.001 Brute Force: Password Guessing](#)

[T1110 Brute Force](#)

[T1078 Valid Accounts](#)

[T1098 Account Manipulation](#)

[T1136.001 Create Account: Local Account](#)

[T1070.001 Indicator Removal: Clear Windows Event Logs](#)

[T1486 Data Encrypted for Impact](#)

[TA0010 Exfiltration \(tactic\)](#)

[TA0011 Command and Control \(tactic\)](#)

[T1562 Impair Defenses](#)

Standards and public guidance

[NIST Cybersecurity Framework 2.0](#) www.nist.gov (NIST: National Institute of Standards and Technology)

[The Cybersecurity Framework 2.0, full text](#) nvlpubs.nist.gov

[CIS \(Center for Internet Security\) Control 13](#) www.cisecurity.org

[CIS Control 8: Audit Log Management](#) www.cisecurity.org

[Canadian Centre for Cyber Security: logging and monitoring](#) www.cyber.gc.ca

[RFC \(Request for Comments\) 5424: The Syslog Protocol](#) www.rfc-editor.org

[RFC 5737: addresses for documentation](#) www.rfc-editor.org

Links and resources (4/4)

Law and privacy

[Commission d'accès à l'information du Québec](http://www.cai.gouv.qc.ca) www.cai.gouv.qc.ca

[Québec private-sector privacy act \(chapter P-39.1\)](http://www.legisquebec.gouv.qc.ca)
www.legisquebec.gouv.qc.ca

[Criminal Code of Canada](http://laws-lois.justice.gc.ca) laws-lois.justice.gc.ca

Further reading

[NIST SP \(Special Publication\) 800-92: log management](http://csrc.nist.gov) csrc.nist.gov

[NIST SP 800-61 Revision 3: incident response](http://csrc.nist.gov) csrc.nist.gov

[Cloudflare: thresholds in security event alerting](http://blog.cloudflare.com) blog.cloudflare.com

How to check a link before opening it

Read the domain: it must be the official site of the organization.

Paste the address into the [VirusTotal address scanner](#).

Second opinion: [Google Safe Browsing](#).

Download software only from its official site and verify its checksum.

Rules: [Legal Notice §14](#) and [Annex C](#).

Questions and discussion

Next class: Thursday, October 8, 2026, Topic 4, event logs and traffic capture.

Quiz 3: Saturday, October 10, 2026.

Companion files: the four programs, the data, the figures and the workbook.



Educational Hub © 2026 | From the Industry to the Classroom — Building the IT's Future, Today and Together !
ALL Rights Reserved

© 2026 Cyber.SoHo.

[Cyber.SoHo Legal Notice, Terms of Use and Acceptable Use Policy](#)